# Annexe technique

## Délégation Kerberos et authentification double-saut (double hop)

*Domaine optimedit.eu — État actuel et scénarios futurs*

Préparé pour : Driss

Complément au Guide d'installation SQL Server 2022 Always On

# Sommaire

Sommaire ..... 2
1. Objet de cette annexe ..... 3
2. Deux mécanismes différents, un même mot ..... 3
2.1 Délégation de contrôle (déjà en place) ..... 3
2.2 Délégation Kerberos / double hop (pas encore en place, pas nécessaire aujourd'hui) ..... 3
3. Comprendre le double hop ..... 4
3.1 Single hop — ce que vous avez aujourd'hui ..... 4
3.2 Double hop — ce qui nécessiterait une délégation ..... 4
4. État futur — quand la délégation double hop deviendra nécessaire ..... 4
5. Exemple concret 1 — IIS vers le Listener Always On (AG-OPTIMEDIT) ..... 5
5.1 Scénario ..... 5
5.2 Méthode A — Délégation contrainte classique ..... 5
5.3 Méthode B — RBCD (Resource-Based Constrained Delegation, recommandée) ..... 5
5.4 Configuration côté IIS ..... 5
5.5 Test de validation ..... 6
6. Exemple concret 2 — IIS vers le serveur de fichiers (OPT-FS03) ..... 7
6.1 Scénario ..... 7
6.2 Configuration RBCD ..... 7
6.3 SPN requis côté OPT-FS03 ..... 7
6.4 Test de validation ..... 7
7. Note sur le reverse proxy ARR (OPT-RP-01) ..... 8
8. Checklist de mise en œuvre (le jour où le besoin apparaît) ..... 8
9. Références rapides (commandes) ..... 8

# 1. Objet de cette annexe

Cette annexe documente la différence entre deux mécanismes Active Directory qui portent des noms proches en français — la délégation de contrôle (permissions administratives sur un annuaire) et la délégation Kerberos (rejeu d'identité entre services, dit « double saut » ou double hop) — et précise, pour l'infrastructure optimedit.eu : ce qui est en place aujourd'hui, pourquoi c'est suffisant dans l'état actuel, et comment configurer une délégation double hop le jour où le besoin apparaît.

> **État actuel :** *aucune délégation Kerberos double hop n'est configurée ni nécessaire aujourd'hui. Seules la délégation de contrôle sur l'OU (chapitres 4.4.2/4.4.3 du guide) et une configuration SPN correcte (nœuds + Listener, chapitre 5.0.0/5.0.0bis) sont en place — et elles suffisent au design actuel.*

# 2. Deux mécanismes différents, un même mot

## 2.1 Délégation de contrôle (déjà en place)

Un modèle de permissions administratives Active Directory, posé sous forme d'ACE sur un objet (une OU, par exemple). Elle répond à la question : qui a le droit de créer, modifier ou supprimer des objets dans l'annuaire ?

- Chez vous : CL-SQL-AG$ dispose de CreateChild/DeleteChild sur l'OU SQL Server, pour pouvoir créer le VCO du Listener Always On (SQL-AG-LSTNR$).
- Aucun rapport avec l'authentification d'un utilisateur ou d'un service — c'est un droit d'administration de l'annuaire, pas un droit de rejouer une identité.

## 2.2 Délégation Kerberos / double hop (pas encore en place, pas nécessaire aujourd'hui)

Un mécanisme distinct qui répond à une question différente : un service a-t-il le droit de réutiliser l'identité d'un utilisateur pour s'authentifier à son tour auprès d'un troisième système ? C'est ce qui est configuré via l'onglet Délégation d'un compte, ou via les attributs msDS-AllowedToDelegateTo / msDS-AllowedToActOnBehalfOfOtherIdentity.

| | Délégation de contrôle | Délégation Kerberos (double hop) |
|---|---|---|
| Répond à | Qui peut créer/modifier des objets AD ? | Un service peut-il rejouer l'identité d'un utilisateur vers un 3e système ? |
| Se configure sur | Un objet AD (OU, conteneur) | Un compte (ordinateur ou service) |
| Chez vous | Fait — CL-SQL-AG$ sur l'OU SQL Server | Non fait, non nécessaire (design actuel) |

# 3. Comprendre le double hop

## 3.1 Single hop — ce que vous avez aujourd'hui

Un client s'authentifie directement auprès d'un service, avec son propre ticket Kerberos. C'est le cas de tous vos tests actuels (sqlcmd, connexion SqlClient) et de vos 13 sites IIS, qui se connectent à SQL Server avec leur propre identité de compte de service (svc_direction, svc_comptabilite, etc.) — jamais avec celle du visiteur du site.

```
[Client] --(Kerberos, ticket du client)--> [Service A]
Un seul saut : pas de délégation requise.
```

## 3.2 Double hop — ce qui nécessiterait une délégation

Un service intermédiaire doit réutiliser l'identité du client pour se connecter à son tour à un second service, en tant que ce client (pas en tant que lui-même).

```
[Client] --(hop 1: Kerberos)--> [Service A] --(hop 2: Kerberos, identite du CLIENT)-->
[Service B]
Sans delegation configuree sur Service A : le hop 2 echoue ou retombe en ANONYMOUS
LOGON.
```

> **Important :** *Kerberos bloque ce rejeu par défaut, pour une raison de sécurité : sans restriction explicite, n'importe quel service compromis pourrait usurper l'identité de tous les utilisateurs qui s'y connectent, vers n'importe quelle autre ressource du domaine. La délégation lève cette restriction, mais seulement pour la cible précise qu'on autorise.*

# 4. État futur — quand la délégation double hop deviendra nécessaire

Avec le design actuel (un compte de service dédié par site IIS), vous n'avez pas de double hop : IIS s'authentifie auprès de SQL Server en tant que lui-même. Le besoin apparaîtrait si vous changiez ce design pour faire circuler l'identité réelle de l'utilisateur jusqu'à la ressource finale. Déclencheurs typiques :

- Sécurité au niveau ligne (row-level security) côté SQL Server, pour qu'un employé RH ne voie que les dossiers de son propre périmètre, évaluée avec le login SQL réel de l'utilisateur plutôt qu'un compte de service partagé.
- Audit nominatif côté base de données (traçabilité SQL native par utilisateur réel, plutôt que par compte de service applicatif).
- Accès à un partage de fichiers (OPT-FS03) où les permissions NTFS doivent s'appliquer à l'utilisateur réel, pas au compte de service du site IIS.
- Authentification Windows intégrée de bout en bout exigée par une application tierce qui ne gère pas ses propres comptes de service.

> **Remarque :** *aucun de ces scénarios n'existe aujourd'hui dans l'infrastructure optimedit.eu. Cette section prépare le terrain si l'un d'eux se présente.*

# 5. Exemple concret 1 — IIS vers le Listener Always On (AG-OPTIMEDIT)

## 5.1 Scénario

Un site (ex. direction.optimedit.eu sur OPT-IIS-01) authentifie le visiteur en Windows intégrée, et doit se reconnecter à SQL-AG-LSTNR avec l'identité réelle de ce visiteur, plutôt qu'avec svc_direction.

```
[Poste utilisateur - driss@OPTIMEDIT]
        |  Hop 1 : Kerberos (authentification Windows integree)
        v
[OPT-IIS-01 - site direction.optimedit.eu]
        |  Hop 2 : IIS doit se reconnecter a SQL 'en tant que driss', pas en tant que
svc_direction
        v
[SQL-AG-LSTNR -> AG-OPTIMEDIT (SQLS01 ou SQLS02, selon le primaire)]
```

## 5.2 Méthode A — Délégation contrainte classique

Sur le compte qui porte l'identité du pool IIS (le compte ordinateur OPT-IIS-01$, ou svc_direction si le pool tourne sous ce compte) :

1. Utilisateurs et ordinateurs Active Directory → propriétés du compte → onglet Délégation.
2. Choisir « Approuver cet ordinateur pour la délégation uniquement aux services spécifiés ».
3. Sélectionner « Utiliser Kerberos uniquement » (pas de protocole de transition, sauf besoin spécifique).
4. Ajouter le service cible : MSSQLSvc/SQL-AG-LSTNR.optimedit.eu:1433.

**Vérification : `Set-ADUser (délégation classique, PowerShell)`** — *exécuté sur : DC03*

```powershell
Set-ADAccountControl -Identity 'svc_direction' -TrustedToAuthForDelegation $false
Set-ADUser -Identity 'svc_direction' -Add @{
'msDS-AllowedToDelegateTo' = 'MSSQLSvc/SQL-AG-LSTNR.optimedit.eu:1433'
    }
```

## 5.3 Méthode B — RBCD (Resource-Based Constrained Delegation, recommandée)

**Configurée à l'envers : côté ressource (SQLS01/SQLS02), pas côté demandeur (IIS). Plus simple à administrer, ne nécessite pas de droit spécial sur le compte IIS, fonctionne entre domaines/forêts sans confiance transitive complète.**

**Vérification : `Set-ADComputer (RBCD)`** — *exécuté sur : SQLS01 et SQLS02*

```powershell
Set-ADComputer SQLS01 -PrincipalsAllowedToDelegateToAccount OPT-IIS-01$
Set-ADComputer SQLS02 -PrincipalsAllowedToDelegateToAccount OPT-IIS-01$

# Verification :
Get-ADComputer SQLS01 -Properties PrincipalsAllowedToDelegateToAccount |
Select -ExpandProperty PrincipalsAllowedToDelegateToAccount
```

**Important :** *piège spécifique Always On : la délégation doit toujours cibler le SPN du Listener (SQL-AG-LSTNR), jamais un SPN de nœud individuel (SQLS01 ou SQLS02). Une délégation pointée sur un nœud casse au premier failover vers l'autre nœud — même classe de piège que ASPState et les jobs SQL Agent déjà rencontrés dans le guide principal.*

## 5.4 Configuration côté IIS

- Authentification Windows activée sur le site, avec le fournisseur Negotiate en premier (pas NTLM seul).

- Le pool d'applications doit tourner avec un identifiant qui a les droits de délégation configurés ci-dessus (le compte ordinateur du serveur, ou un compte de service dédié — pas ApplicationPoolIdentity, qui ne peut pas porter de délégation).
- Côté code applicatif (.NET) : ouvrir la connexion SQL avec Integrated Security=True après avoir impersonné l'identité Windows du visiteur (WindowsIdentity.Impersonate), plutôt qu'avec la chaîne de connexion statique actuelle.

### 5.5 Test de validation

```
# Depuis OPT-IIS-01, en tant que l'utilisateur impersonne (ou via un test applicatif) :
sqlcmd -S SQL-AG-LSTNR.optimedit.eu -E -Q "SELECT SYSTEM_USER, auth_scheme FROM
sys.dm_exec_connections WHERE session_id = @@SPID"
# SYSTEM_USER doit afficher OPTIMEDIT\driss (l'utilisateur reel), pas svc_direction
# auth_scheme doit afficher KERBEROS
```

# 6. Exemple concret 2 — IIS vers le serveur de fichiers (OPT-FS03)

## 6.1 Scénario

Une application IIS doit lire ou écrire des fichiers sur \\OPT-FS03\... en respectant les permissions NTFS propres à chaque utilisateur, plutôt que celles du compte de service applicatif.

```
[Poste utilisateur] --(hop 1)--> [OPT-IIS-0x] --(hop 2, identite du client)--> [OPT-FS03
- partage SMB]
```

## 6.2 Configuration RBCD

**Vérification : `Set-ADComputer (RBCD vers le partage de fichiers)`** — *exécuté sur : OPT-FS03*

```
Set-ADComputer OPT-FS03 -PrincipalsAllowedToDelegateToAccount OPT-IIS-01$

# Verification :
Get-ADComputer OPT-FS03 -Properties PrincipalsAllowedToDelegateToAccount |
 Select -ExpandProperty PrincipalsAllowedToDelegateToAccount
```

## 6.3 SPN requis côté OPT-FS03

Le SPN cible pour un partage de fichiers est de classe cifs, pas MSSQLSvc :

```
setspn -L OPT-FS03$
# Doit contenir : cifs/OPT-FS03 et cifs/OPT-FS03.optimedit.eu
# Si absent :
setspn -S cifs/OPT-FS03.optimedit.eu OPT-FS03$
```

## 6.4 Test de validation

```
# Depuis OPT-IIS-01, apres impersonation de l'utilisateur :
klist
# Doit contenir un ticket de service pour cifs/OPT-FS03.optimedit.eu
Test-Path "\\OPT-FS03\PartageRestreint\fichier_test.txt"
# Doit reussir ou echouer selon les permissions NTFS de l'utilisateur reel, pas du compte de
service
```

## 7. Note sur le reverse proxy ARR (OPT-RP-01)

> **Important :** *OPT-RP-01 étant devant tous les sites IIS, un scénario double hop complet devient en réalité un scénario à trois sauts (client → ARR → IIS → SQL/fichier). ARR (Application Request Routing) ne gère pas nativement la délégation Kerberos : par défaut, il transmet la requête HTTP au backend sans rejouer l'identité Windows du client.*

- Si ARR authentifie lui-même le client puis se connecte au backend avec sa propre identité, il faudrait déléguer ARR → IIS en plus de IIS → SQL (deux délégations chaînées, plus complexe à valider).
- Alternative plus simple et plus courante : configurer ARR en pass-through pour l'authentification (préserver l'en-tête d'authentification du client jusqu'au serveur IIS backend, qui gère alors l'auth Kerberos lui-même) plutôt que de faire authentifier ARR.

> **Remarque :** *si ce besoin se présente, valider d'abord le double hop IIS → SQL (chapitre 5) en accédant directement à un site IIS sans passer par ARR, avant d'ajouter la complexité du reverse proxy.*

## 8. Checklist de mise en œuvre (le jour où le besoin apparaît)

5. Confirmer que le scénario applicatif exige réellement l'identité réelle de l'utilisateur (RLS, audit nominatif, permissions fichier) — sinon, garder le design actuel par compte de service.
6. Activer l'authentification Windows sur le site IIS concerné, fournisseur Negotiate en premier.
7. Configurer la RBCD côté ressource (SQLS01+SQLS02, ou OPT-FS03) vers le compte porteur du pool IIS.
8. Vérifier les SPN de la cible (MSSQLSvc/SQL-AG-LSTNR pour SQL, cifs/OPT-FS03 pour le partage).
9. Adapter le code applicatif pour impersoner l'utilisateur avant l'appel au service cible.
10. Tester avec klist et SYSTEM_USER/auth_scheme comme aux sections 5.5 et 6.4.
11. Si un reverse proxy est dans le chemin, valider le hop IIS → cible seul avant d'ajouter ARR.

## 9. Références rapides (commandes)

| Besoin | Commande |
|---|---|
| Voir la délégation actuelle d'un compte | `Get-ADUser <compte> -Properties msDS-AllowedToDelegateTo` |
| Configurer RBCD sur une ressource | `Set-ADComputer <ressource> -PrincipalsAllowedToDelegateToAccount <demandeur>$` |
| Vérifier les SPN d'une cible | `setspn -L <compte>` |
| Voir les tickets en cache (côté client/IIS) | `klist` |
| Vérifier l'auth_scheme réel côté SQL | `SELECT SYSTEM_USER, auth_scheme FROM sys.dm_exec_connections WHERE session_id=@@SPID` |